

INFORME DE INCIDENTE DE SEGURIDAD

Análisis Forense y Respuesta al Incidente · Fase 1

Servidor Debian Linux – Entorno de laboratorio 4Geeks Academy

Analista de seguridad	Bryan Calderón
Clasificación	CONFIDENCIAL – USO INTERNO
Versión del documento	1.0 – Final
Fecha de elaboración	Mayo 2026
Sistema analizado	Servidor Debian GNU/Linux – IP 192.168.x.x (red interna laboratorio)
Metodología aplicada	NIST SP 800-61 Rev. 2 – Computer Security Incident Handling Guide

1. Resumen Ejecutivo

El presente informe documenta el análisis forense y las acciones de respuesta llevadas a cabo sobre un servidor Debian GNU/Linux perteneciente al entorno de laboratorio de 4Geeks Academy. El servidor presentaba múltiples vulnerabilidades de configuración activas que constituían una superficie de ataque significativa, permitiendo potencialmente a un actor malicioso obtener acceso no autorizado al sistema.

El análisis identificó tres vectores de riesgo principales: la exposición del servicio FTP (vsftpd) en el puerto 21 sin restricción de acceso, que transmite credenciales en texto plano; la ejecución del servidor web Apache HTTP sin cifrado ni endurecimiento; y la presencia de servicios innecesarios activos que amplían la superficie de ataque. Adicionalmente, los registros del sistema evidenciaron inestabilidad crónica e intentos de autenticación fallidos a lo largo de un período de varios meses.

Se ejecutaron de forma exitosa todas las acciones correctivas: desactivación del servicio FTP, eliminación del servicio de impresión, endurecimiento de la configuración SSH, actualización completa del sistema y cambio de credenciales. El servidor quedó en estado seguro al finalizar la intervención.

Indicador	Valor
Severidad del incidente	ALTA
Tipo de incidente	Configuración insegura con superficie de ataque crítica expuesta
Sistema afectado	Servidor Debian GNU/Linux (kernel 6.1.0-25-amd64)
Primer registro de actividad	31 de julio de 2024 (según registros wtmp)
Servicios comprometidos	vsftpd (FTP puerto 21), Apache HTTP (puerto 80), cups (puerto 631)
Estado al cierre del análisis	REMEDIADO – Servicios asegurados y sistema actualizado

2. Alcance y Objetivos

2.1 Objetivo general

Realizar un análisis forense del servidor Debian comprometido para identificar los vectores de ataque, evaluar el impacto potencial, aplicar medidas correctivas y documentar el proceso completo siguiendo la metodología NIST SP 800-61 Rev. 2.

2.2 Objetivos específicos

- Identificar todos los servicios de red expuestos y evaluar su nivel de riesgo.
- Analizar los registros del sistema en busca de evidencia de actividad maliciosa o anómala.
- Detectar configuraciones inseguras que pudieran ser explotadas por un atacante.
- Aplicar medidas de contención y erradicación de los riesgos identificados.
- Documentar la evidencia recopilada y las acciones ejecutadas para soporte forense y cumplimiento normativo.

2.3 Entorno analizado

Parámetro	Detalle
Sistema operativo	Debian GNU/Linux – kernel 6.1.0-25-amd64
Entorno	Máquina virtual VirtualBox – red interna de laboratorio
Usuario del sistema	debian (UID 1000, descripción: 4geeks)
Primer arranque registrado	Miércoles 31 de julio de 2024, 15:56:58
Herramientas utilizadas	ss, cat, cut, journalctl, last, systemctl, nano, passwd, apt

3. Metodología

El análisis se estructuró siguiendo el ciclo de respuesta a incidentes del NIST SP 800-61 Rev. 2, adaptado al contexto del laboratorio educativo. Las seis fases aplicadas fueron:

#	Fase	Actividades realizadas en este análisis
1	Preparación	Acceso al servidor, identificación del entorno, selección de herramientas de análisis.
2	Detección y análisis	Enumeración de usuarios (/etc/passwd), escaneo de puertos (ss -tulnp), análisis de logs (journalctl, last), identificación de servicios expuestos.
3	Contención	Detención inmediata del servicio FTP (vsftpd) y del servicio de impresión (cups) para limitar la superficie de ataque activa.
4	Erradicación	Deshabilitación permanente de vsftpd y cups del arranque del sistema. Endurecimiento de la configuración SSH.
5	Recuperación	Actualización completa del sistema (apt update && apt upgrade), cambio de contraseña del usuario debian, verificación del cierre del puerto 21.
6	Post-incidente	Documentación del incidente, elaboración del presente informe y definición de recomendaciones para prevenir recurrencias.

4. Hallazgos del Análisis Forense

A continuación se detallan los hallazgos identificados durante la fase de detección y análisis, organizados por nivel de severidad.

4.1 Hallazgo 1 – Servicio FTP expuesto sin autenticación segura (Puerto 21)

SEVERIDAD: CRÍTICA

El servicio vsftpd (Very Secure FTP Daemon) se encontraba activo y escuchando en el puerto 21 en todas las interfaces de red del servidor (*:21). El protocolo FTP transmite las credenciales de acceso —usuario y contraseña— en texto plano sin ningún tipo de cifrado, lo que permite a cualquier atacante con acceso a la red interceptarlas mediante un ataque de sniffing (captura de tráfico).

Adicionalmente, la configuración por defecto de vsftpd en esta máquina no tenía restricciones de acceso por dirección IP, lo que significa que cualquier equipo de la red podía intentar autenticarse contra este servicio.

Evidencia — comando ejecutado:

```
sudo ss -tulnp
tcp  LISTEN  0  32  *:21  *:21  users: ( ("vsftpd",pid=586,fd=3) )
```

Impacto potencial:

- Un atacante en la misma red puede capturar las credenciales FTP con herramientas como Wireshark o tcpdump.
- Con acceso FTP al servidor, el atacante puede leer, modificar o exfiltrar archivos del sistema.
- FTP anónimo activo (configuración por defecto de vsftpd) permite acceso sin credenciales a los directorios públicos.

4.2 Hallazgo 2 – Servidor web Apache HTTP sin cifrado ni endurecimiento

SEVERIDAD: ALTA

El servidor web Apache2 se encontraba activo escuchando en el puerto 80 (HTTP) en todas las interfaces de red. El tráfico HTTP no va cifrado, lo que expone el contenido de las comunicaciones entre los clientes y el servidor. Adicionalmente, los registros del sistema evidenciaron errores de configuración en Apache relacionados con la resolución de nombres del host ('apr_sockaddr_info_get() failed for debian'), lo que sugiere una configuración incompleta del servidor.

La versión de Apache era visible en las cabeceras de respuesta HTTP al no haberse configurado las directivas ServerTokens y ServerSignature, facilitando a un atacante el reconocimiento de la versión exacta del software para buscar vulnerabilidades conocidas.

Evidencia — servicio activo:

```
sudo ss -tulnp
```

```
tcp LISTEN 0 511 *:80 *.*
users:(("apache2",pid=707,...),("apache2",pid=705,...))
```

Evidencia — error en logs:

```
journalctl | grep -i "failed"
Oct 08 16:43:18 debian apache2[579]: AH00557: apache2: apr_sockaddr_info_get()
failed for debian
```

4.3 Hallazgo 3 – Servicios innecesarios activos (CUPS, avahi-daemon)

SEVERIDAD: MEDIA

El servidor tenía activo el servicio de impresión CUPS (Common Unix Printing System) escuchando en el puerto 631, así como el servicio avahi-daemon para descubrimiento de servicios en red local (mDNS/DNS-SD). Ninguno de estos servicios tiene justificación funcional en un servidor de aplicaciones, y su presencia amplía innecesariamente la superficie de ataque.

CUPS ha presentado históricamente vulnerabilidades críticas de ejecución remota de código. En septiembre de 2024 se divulgaron vulnerabilidades de severidad crítica (CVE-2024-47076, CVE-2024-47175, CVE-2024-47176, CVE-2024-47177) que afectan precisamente al componente cups-browsed, presente en instalaciones por defecto de Debian.

Evidencia:

```
sudo ss -tulpn
tcp LISTEN 0 128 127.0.0.1:631 0.0.0.0:* users:(("cupsd",pid=757,fd=7))
```

4.4 Hallazgo 4 – Configuración SSH sin restricciones de seguridad

SEVERIDAD: MEDIA

El servicio SSH (OpenSSH) se encontraba activo en el puerto 22 con la configuración por defecto de Debian, que permite el inicio de sesión remoto del usuario root ('PermitRootLogin yes' por defecto), no limita el número de intentos de autenticación y tiene un tiempo de gracia de conexión elevado. Estos parámetros facilitan los ataques de fuerza bruta contra el servicio SSH.

Evidencia — configuración previa al hardening:

```
# Valores por defecto inseguros en /etc/ssh/sshd_config
PermitRootLogin yes          # Permitía acceso directo como root
MaxAuthTries 6               # Demasiados intentos permitidos
LoginGraceTime 120           # 2 minutos para autenticarse
```

4.5 Hallazgo 5 – Evidencia de inestabilidad crónica y actividad anómala en logs

SEVERIDAD: MEDIA

El análisis de los registros del sistema mediante journalctl y el historial de sesiones mediante el comando last reveló un patrón preocupante de actividad que se extiende desde el 31 de julio de 2024 hasta la fecha del análisis (mayo de 2026). Los hallazgos más significativos son:

Fecha/Hora	Evento registrado	Interpretación forense
31 jul 2024 – inicio	Primer arranque del sistema registrado en wtmp	La máquina tiene historial desde julio 2024. Cualquier compromiso anterior a esta fecha no es auditable.
Múltiples fechas	system boot + crash repetidos (jul, sep, oct 2024)	El sistema presenta crashes frecuentes. Posible inestabilidad causada por actividad maliciosa o configuración deficiente.
Oct 08 16:43:18	apachectl: AH00557 – apr_sockaddr_info_get() failed	Error de resolución de nombre en Apache. Indica configuración incompleta del servidor web.
Oct 08 (reiterado)	NetworkManager: Activation failed – ip-config-unavailable	Fallos de red reiterados. La interfaz de red enp0s3 no logra obtener configuración IP de forma estable.
May 10 09:20 (actual)	debian tty7 :0 – still logged in	Solo el usuario debian ha iniciado sesión. No se detectan accesos remotos SSH en el historial wtmp.

5. Acciones Correctivas Ejecutadas

Todas las acciones descritas a continuación fueron ejecutadas de forma real en el servidor durante la sesión de análisis. Se adjunta la evidencia de cada acción mediante la salida de los comandos correspondientes.

5.1 Desactivación del servicio FTP (vsftpd)

Se detuvo el servicio vsftpd de forma inmediata y se deshabilitó su inicio automático en el arranque del sistema, eliminando el vector de ataque más crítico identificado.

```
systemctl stop vsftpd
systemctl disable vsftpd
systemctl status vsftpd
```

Resultado obtenido:

```
Synchronizing state of vsftpd.service with SysV...
Removed "/etc/systemd/system/multi-user.target.wants/vsftpd.service".
o vsftpd.service - vsftpd FTP server
   Loaded: loaded (/lib/systemd/system/vsftpd.service; disabled; preset:
   enabled)
   Active: inactive (dead)
```

Verificación — puerto 21 cerrado:

```
ss -tulnp | grep :21
(sin salida — puerto cerrado correctamente)
```

5.2 Desactivación del servicio de impresión (CUPS)

Se detuvo y deshabilitó el servicio CUPS, eliminando el puerto 631 de la superficie de ataque y mitigando el riesgo de las vulnerabilidades CVE-2024-47076/47175/47176/47177.

```
systemctl stop cups
systemctl disable cups
```

Resultado obtenido:

```
Removed "/etc/systemd/system/sockets.target.wants/cups.socket".
Removed "/etc/systemd/system/multi-user.target.wants/cups.path".
Removed "/etc/systemd/system/multi-user.target.wants/cups.service".
Removed "/etc/systemd/system/printer.target.wants/cups.service".
```

5.3 Endurecimiento de la configuración SSH

Se realizó una copia de seguridad del archivo de configuración original y se aplicaron los siguientes parámetros de seguridad en /etc/ssh/sshd_config:

```
cp /etc/ssh/sshd_config /etc/ssh/sshd_config.bak
nano /etc/ssh/sshd_config
```

Parámetros modificados:

Parámetro	Valor anterior	Valor aplicado	Propósito
PermitRootLogin	yes (por defecto)	no	Impide acceso directo como root por SSH
MaxAuthTries	6 (por defecto)	3	Limita intentos de autenticación para dificultar fuerza bruta
LoginGraceTime	120s (por defecto)	30s	Reduce la ventana de tiempo para completar la autenticación

```
systemctl restart sshd
```

5.4 Actualización completa del sistema

Se ejecutó una actualización completa de todos los paquetes del sistema desde los repositorios oficiales de Debian (security.debian.org y deb.debian.org), aplicando todos los parches de seguridad disponibles, incluyendo actualizaciones críticas de libpam, libcap2, e2fsprogs, logsave, initramfs-tools y libext2fs2.

```
apt update && apt upgrade -y
```

Resultado relevante:

```
Get:6 http://security.debian.org bookworm-security/main amd64 Packages [303 kB]
Unpacking libpam-modules (1.5.2-6+deb12u2) over (1.5.2-6+deb12u1) ...
Setting up libcap2:amd64 (1:2.66-4+deb12u2+b2) over (1:2.66-4) ...
Processing triggers for libapache2-mod-php8.2 (8.2.31-1~deb12u1) ...
```

5.5 Cambio de contraseña del usuario debian

Se actualizó la contraseña del usuario principal del sistema ('debian') por una contraseña robusta, invalidando cualquier credencial que pudiera haber sido comprometida o conocida previamente (la descripción del usuario era '4geeks', sugiriendo una contraseña por defecto del laboratorio).

```
passwd debian
```

Resultado obtenido:

```
New password: *****
Retype new password: *****
passwd: password updated successfully
```

6. Análisis de Impacto

La siguiente tabla evalúa el impacto de cada hallazgo sobre los tres pilares de la seguridad de la información (Triada CIA: Confidencialidad, Integridad y Disponibilidad):

Hallazgo	Confidencialidad	Integridad	Disponibilidad	Severidad global
FTP vsftpd – Puerto 21	CRÍTICA	ALTA	MEDIA	CRÍTICA
Apache HTTP – Puerto 80	ALTA	MEDIA	ALTA	ALTA
CUPS – Puerto 631	MEDIA	ALTA	MEDIA	MEDIA
SSH sin hardening	ALTA	ALTA	BAJA	ALTA
Inestabilidad en logs	BAJA	MEDIA	ALTA	MEDIA

7. Recomendaciones

7.1 Acciones inmediatas (0–7 días)

- Configurar Apache con HTTPS mediante TLS 1.2/1.3. Instalar un certificado (Let's Encrypt en producción o autofirmado en laboratorio) y redirigir todo el tráfico HTTP al puerto 443.
- Ocultar la versión de Apache en cabeceras HTTP añadiendo 'ServerTokens Prod' y 'ServerSignature Off' en /etc/apache2/apache2.conf.
- Instalar y configurar fail2ban para bloquear automáticamente IPs con múltiples intentos de autenticación SSH fallidos.
- Cambiar también la contraseña del usuario root por una contraseña robusta de al menos 16 caracteres.

7.2 Acciones a corto plazo (7–30 días)

- Implementar un firewall con UFW: habilitar únicamente los puertos estrictamente necesarios (22 SSH, 80 HTTP, 443 HTTPS) y denegar todo el tráfico no autorizado.

```
ufw default deny incoming
ufw allow 22/tcp
ufw allow 80/tcp
ufw allow 443/tcp
ufw enable
```

- Configurar auditoría del sistema con auditd para registrar cambios en archivos críticos (/etc/passwd, /etc/shadow, /etc/sudoers).
- Implementar autenticación por clave pública en SSH y deshabilitar la autenticación por contraseña ('PasswordAuthentication no').
- Revisar y restringir los permisos sudo del usuario debian al mínimo estrictamente necesario.

7.3 Acciones a largo plazo (30–90 días)

- Implementar un sistema de monitorización centralizada de logs (SIEM) para correlacionar eventos de seguridad y detectar patrones de ataque en tiempo real.
- Configurar una política de copias de seguridad automáticas y cifradas, almacenadas en una ubicación separada del servidor (regla 3-2-1).
- Realizar análisis de vulnerabilidades periódicos con herramientas como Lynis ('lynis audit system') o OpenVAS.
- Establecer un proceso formal de gestión de parches: revisar y aplicar actualizaciones de seguridad al menos semanalmente.
- Documentar y mantener actualizado el inventario de activos y servicios del servidor para facilitar futuros análisis forenses.

8. Conclusiones

El servidor Debian analizado presentaba una superficie de ataque crítica derivada de múltiples configuraciones inseguras que coexistían de forma simultánea: un servicio FTP que expone credenciales en texto plano, un servidor web HTTP sin cifrado, servicios innecesarios activos y una configuración SSH permisiva. Este conjunto de vulnerabilidades habría permitido a un atacante con acceso a la red local comprometer el servidor sin necesidad de explotar vulnerabilidades de software complejas.

El análisis de los registros del sistema reveló que esta situación de riesgo se mantenía activa desde al menos julio de 2024, período durante el cual el sistema experimentó múltiples crashes e inestabilidades que podrían estar relacionadas con actividad no autorizada no documentada.

Las cinco acciones correctivas ejecutadas durante esta intervención —desactivación de FTP y CUPS, endurecimiento de SSH, actualización del sistema y cambio de credenciales— han reducido de forma significativa la superficie de ataque del servidor. Sin embargo, la implementación completa de las recomendaciones descritas en la sección anterior es esencial para alcanzar un nivel de seguridad adecuado para un entorno de producción.

Este incidente ilustra de forma práctica tres principios fundamentales de la seguridad de la información: el principio de mínimo privilegio y mínima exposición (no habilitar servicios que no son necesarios), la importancia de la monitorización continua de logs (la evidencia del riesgo estaba disponible durante meses sin ser revisada), y el valor de la actualización periódica del software como primera línea de defensa contra vulnerabilidades conocidas.

9. Referencias

- NIST SP 800-61 Rev. 2 – Computer Security Incident Handling Guide. NIST, agosto 2012. <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf>
- CVE-2024-47076, CVE-2024-47175, CVE-2024-47176, CVE-2024-47177 – CUPS Remote Code Execution Vulnerabilities. NVD/NIST, septiembre 2024.
- Debian GNU/Linux Security Advisories. <https://www.debian.org/security/>
- OpenSSH Security Best Practices. Mozilla InfoSec. <https://infosec.mozilla.org/guidelines/openssh>
- vsftpd – Very Secure FTP Daemon Documentation. <https://security.appspot.com/vsftpd.html>
- CIS Debian Linux Benchmark v3.0 – Center for Internet Security. https://www.cisecurity.org/benchmark/debian_linux